

README — Kit FAICP 2025-2026

Guía de Uso del Kit Completo de Evaluación de Ciberseguridad IA

"Este kit no nació para ser archivado. Nació para ser usado, discutido, contradicho y mejorado."

Versión: 1.0 — Abril 2026

Autoría: Consorcio FAICP — CISOs, Criptógrafos, Arquitectos Zero Trust, Teóricos del Riesgo Actuarial, Estrategas de Ciberseguridad

Distribución: Libre con atribución

Licencia: CC BY 4.0 — Reconocimiento 4.0 Internacional

¿Qué es el Kit FAICP?

El **Kit FAICP 2025-2026** es un conjunto completo de herramientas metodológicas, analíticas y de comunicación para que organizaciones españolas —y con perspectiva comparativa mundial— evalúen, planifiquen y mejoren su postura de ciberseguridad específica para sistemas de inteligencia artificial.

El kit integra los marcos más relevantes y recientes en la materia:

- NIST IR 8596 (Cyber AI Profile, publicado diciembre 2025) — el documento más reciente y completo
- NIST AI RMF 1.0 (AI 100-1) — gestión de riesgos de IA
- EU AI Act 2024/1689 — el reglamento europeo de inteligencia artificial
- ENS RD 311/2022 — Esquema Nacional de Seguridad español
- NIS2 Directiva 2022/2555 — ciberseguridad de operadores esenciales e importantes
- ISO/IEC 42001:2023 — sistema de gestión de inteligencia artificial
- OWASP LLM Top 10 2025 — vulnerabilidades específicas de grandes modelos de lenguaje
- MITRE ATLAS v5.5 (marzo 2026) — amenazas adversariales a sistemas de IA

Estructura del Kit

El kit se compone de **7 documentos**, cada uno con un propósito específico y una audiencia definida:

Archivo	Título	Propósito	Audiencia Principal
00_INFORME-FAICP-2025-2026.md	Informe Principal FAICP	Marco conceptual, estado del arte 2025-2026, perspectiva territorial por CCAA y comparativa mundial	CISO, Directivos, Investigadores
a_marco-gqm-pragmatic.md	Marco Integrativo GQM + PRAGMATIC	Fundamentación metodológica y trazabilidad objetivo → métrica	CISO, Arquitectos de Seguridad IA, Auditores
b_matriz-pragmatic-faicp.md	Matriz PRAGMATIC Completa	Calificación de los 29 indicadores en 9 criterios de calidad	Analistas de Riesgos, Auditores, Consultores GRC
c_narrativa-faicp.md	Narrativa Explicativa	Por qué cada decisión metodológica, limitaciones y cómo usar el marco	CISO, CRO, Responsables de GRC
d_mapeo-normativo-faicp.md	Mapeo Normativo Detallado	Trazabilidad pregunta GQM – artículo normativo → régimen sancionador	DPO, Asesoría Jurídica, Compliance, Auditores
e_plantilla-igm-roi-faicp.md	Plantilla IGM + ROI (Excel)	Especificación técnica completa de la calculadora Excel	Analistas, Consultores, Responsables de Ciberseguridad
f_plantilla-ppt-faicp.md	Plantilla PowerPoint	24 diapositivas especificadas para el reporte ejecutivo	CISO para presentaciones a Consejo, Comité de Riesgos

Cómo Usar el Kit: Flujo de Trabajo Recomendado

FASE 0 — Preparación (2-3 días)

Objetivo: Entender el contexto antes de medir.

1. Leer el Informe Principal (00_INFORME-FAICP-2025-2026.md) — Especialmente las Partes I y III para entender el marco y la situación española.
2. Leer la Narrativa Explicativa (c_narrativa-faicp.md) — Para entender las decisiones metodológicas y evitar los errores más comunes.
3. Revisar el Mapeo Normativo (d_mapeo-normativo-faicp.md) — Para identificar qué obligaciones legales aplican a su organización según su perfil (OE/OI NIS2, AAPP ENS, ProvIA/DesplIA EU AI Act, EntFin DORA).

Pregunta clave de esta fase: ¿Cuáles de los 5 perfiles regulatorios aplican a mi organización?

FASE 1 — Autoevaluación IGM-FAICP (3-5 días)

Objetivo: Establecer el baseline de madurez con la mayor honestidad posible.

4. Implementar la Plantilla Excel siguiendo las especificaciones de e_plantilla-igm-roi-faicp.md:
5. Crear el archivo en Excel/Google Sheets con las 7 hojas especificadas
6. Completar la HOJA 2 (Datos de la Organización)
7.
Puntuar los 29 indicadores en la HOJA 3 (Autoevaluación)
8.
Principio de genuinidad: Puntuar con honestidad. Cuando haya duda entre puntuar 2 o 3, puntuar 2. La subvaloración honesta es más útil que la sobrevaloración optimista.
9.
Recoger evidencias: Para cada indicador, documentar en la columna G de la HOJA 3 la evidencia que respalda la puntuación (documento, fecha, sistema).
10.
Calcular el IGM-FAICP total (HOJA 4 — cálculo automático).

Puntuar los 29 indicadores en la HOJA 3 (Autoevaluación)

Principio de genuinidad: Puntuar con honestidad. Cuando haya duda entre puntuar 2 o 3, puntuar 2. La subvaloración honesta es más útil que la sobrevaloración optimista.

Recoger evidencias: Para cada indicador, documentar en la columna G de la HOJA 3 la evidencia que respalda la puntuación (documento, fecha, sistema).

Calcular el IGM-FAICP total (HOJA 4 — cálculo automático).

Indicadores Tier 1 que no pueden quedar sin puntuar:

Código	Indicador
IGM-GV-01	Política formal de ciberseguridad para IA
IGM-GV-02	Mapa de dependencias de infraestructura IA
IGM-GV-03	Formación en amenazas IA adversarial
IGM-GV-04	Evaluación de proveedores de IA
IGM-ID-01	AI-BOM completo
IGM-ID-02	Evaluación vulnerabilidades OWASP LLM Top 10
IGM-ID-05	Análisis cadena de suministro IA
IGM-PR-01	IAM para sistemas y agentes IA
IGM-PR-02	Menor privilegio en agentes IA
IGM-PR-03	Formación en amenazas IA
IGM-PR-04	Protección datos de entrenamiento
IGM-DE-01	Monitorización de APIs IA externas
IGM-DE-02	Monitorización en tiempo de ejecución
IGM-DE-05	Controles de detección prompt injection
IGM-RS-01	Playbooks de respuesta IA
IGM-RS-03	Plazos de notificación regulatoria
IGM-RS-04	MTTR-AI medido
IGM-RC-01	Planes de recuperación con rollback
IGM-RC-02	RTO-AI definido y verificado

FASE 2 — Análisis de Calidad de Métricas (1 día)

Objetivo: Verificar que las métricas utilizadas son de calidad suficiente.

- Revisar la Matriz PRAGMATIC (b_matriz-pragmatic-faicp.md) para cada indicador donde la puntuación sea ≤ 3 .
- Prestar especial atención al criterio G (Genuino) — ¿hay riesgo de que la puntuación asignada sea optimista?
- Para los 3 indicadores condicionales (IGM-ID-03, IGM-DE-04, IGM-RS-02), interpretar las puntuaciones bajas con el contexto: son difíciles para todas las organizaciones, no solo para la propia.

FASE 3 — Modelo de ROI (1-2 días)

Objetivo: Construir el caso de negocio para la inversión en mejora.

14. Completar la HOJA 5 (ROI Ciberseguridad IA) de la plantilla Excel con:
15. Coste estimado de un incidente IA en su organización
16. Número de incidentes esperados sin mejoras (usar como referencia: si el sector tiene perfil similar al español, la probabilidad es del 87% de sufrir al menos uno)
17.
 Inversión prevista por fase
18.
 Calcular los tres escenarios (conservador, base, optimista).
19.
 Añadir las multas regulatorias potenciales para su perfil normativo específico (ver d_mapeo-normativo-faicp.md — Sección: Cuadro Sinóptico de Marcos).

Inversión prevista por fase

Calcular los tres escenarios (conservador, base, optimista).

Añadir las multas regulatorias potenciales para su perfil normativo específico (ver d_mapeo-normativo-faicp.md — Sección: Cuadro Sinóptico de Marcos).

FASE 4 — Plan de Acción (2 días)

Objetivo: Pasar de los números a las acciones.

20.
 La HOJA 6 de la plantilla Excel extrae automáticamente los indicadores con puntuación ≤ 3 , priorizados por Tier y puntuación.
21.
 Para cada brecha identificada:
22. Definir la acción concreta de mejora (columna I de HOJA 3)
23. Asignar un responsable nominado (columna J)
24.
 Establecer una fecha objetivo realista (columna K)
25.
 Las acciones de Tier 1 con puntuación ≤ 2 son las de mayor urgencia. Si hay más de 3 en esta categoría, se recomienda considerar apoyo externo.

La HOJA 6 de la plantilla Excel extrae automáticamente los indicadores con puntuación ≤ 3 , priorizados por Tier y puntuación.

Para cada brecha identificada:

Establecer una fecha objetivo realista (columna K)

Las acciones de Tier 1 con puntuación ≤ 2 son las de mayor urgencia. Si hay más de 3 en esta categoría, se recomienda considerar apoyo externo.

FASE 5 — Comunicación Ejecutiva (1 día)

Objetivo: Presentar los resultados y obtener el mandato para las mejoras.

26. Usar la Plantilla PowerPoint (f_plantilla-ppt-faicp.md) para preparar la presentación.
27. Personalizar con los datos reales de las fases anteriores.
28. Para el Consejo de Administración: diapositivas 01, 02, 04, 05, 13, 18, 19, 21, 22, 24.
29. Para el Comité de Riesgos o CISO técnico: presentación completa (24 slides + apéndices).

Preguntas Frecuentes (FAQ)

"¿Este kit reemplaza al ENS o al ISO 27001?"

No. El Kit FAICP es **complementario** a los marcos de seguridad existentes. El ENS y el ISO 27001 son marcos horizontales de ciberseguridad. El FAICP es un marco **vertical** específico para sistemas de IA. La relación es: ENS/ISO 27001 es el suelo sobre el que se construye, FAICP es el piso específico de la IA.

"¿Quién debe liderar la autoevaluación?"

El CISO, con la participación del responsable de sistemas de IA (si existe como rol diferenciado), el DPO (para los indicadores relacionados con RGPD y EU AI Act) y, idealmente, un evaluador externo independiente para aumentar el criterio G (Genuino) del PRAGMATIC.

"¿Con qué frecuencia debo actualizar la evaluación?"

- Indicadores Tier 1: Revisión semestral como mínimo
- Evaluación completa: Anual
- Revisión extraordinaria: Ante publicación de nuevas versiones de MITRE ATLAS, OWASP LLM Top 10, o nuevas guías de AESIA/CCN; ante incidentes de IA significativos en el sector

"¿Puedo compartir mi IGM-FAICP con AESIA o INCIBE?"

Se anima a ello. La agregación de datos IGM-FAICP por sector y CCAA permitiría a INCIBE y AESIA identificar brechas sistémicas y dirigir mejor los recursos de apoyo. El intercambio voluntario de datos anonimizados contribuye al benchmarking nacional.

"Mi puntuación IGM-FAICP es 1.5. ¿Es muy mala?"

Es la puntuación de la mayoría de las organizaciones en España en este momento. El Cisco CRI 2025 sitúa el promedio español en niveles equivalentes a 1.4-1.5 en la escala del FAICP. Lo relevante no es el punto de partida sino la trayectoria. Un IGM de 1.5 con plan de mejora ejecutado es infinitamente preferible a un IGM de 3.0 documentado en papel sin implementación real.

"¿Qué ocurre con los tres indicadores 'condicionales'?"

IGM-ID-03, IGM-DE-04 e IGM-RS-02 son condicionales no porque sean poco importantes, sino porque el mercado de capacidades (feeds CTI para IA, capacidades SOC para ATLAS, forense de IA) no ha madurado lo suficiente para que la mayoría de organizaciones puedan implementarlos. Medir estas brechas es el primer paso para cerrarlas; no hay que desanimarse por puntuaciones bajas en ellos.

"¿Cuánto cuesta implementar el kit?"

El kit en sí es gratuito. El coste de implementación depende del tamaño de la organización y las brechas detectadas. Como referencia orientativa:

Fase	Coste estimado PYME	Coste estimado Gran Empresa
Autoevaluación interna	0 - 5.000€ (tiempo interno)	10.000-30.000€
Apoyo consultor experto	5.000-15.000€	20.000-60.000€
Implementación Fase 1 (Tier 1)	10.000-50.000€	100.000-500.000€
Herramientas de monitorización IA	5.000-20.000€/año	50.000-200.000€/año

Recursos de Referencia

Organismos Nacionales

Organismo	Rol	Contacto
AESIA	Autoridad de supervisión EU AI Act en España	aesia.digital.gob.es
INCIBE	Centro Nacional de Ciberseguridad (empresas y ciudadanos)	incibe.es · 017 (24h)
CCN-CERT	CERT Nacional (AAPP y operadores críticos)	ccn-cert.cni.es
AEPD	Agencia Española de Protección de Datos	aepd.es

Documentos Fundacionales del Marco

Documento	URL
NIST IR 8596 (borrador dic. 2025)	nvlpubs.nist.gov
NIST AI RMF 1.0	airc.nist.gov
EU AI Act (texto consolidado)	eur-lex.europa.eu
OWASP LLM Top 10 2025	owasp.org/www-project-top-10-for-large-language-model-applications
MITRE ATLAS v5.5	atlas.mitre.org
ENISA Threat Landscape 2025	enisa.europa.eu
ENS RD 311/2022	ccn.cni.es

Créditos y Descargos

Marco de Referencia Primario

Este kit está basado en documentos de libre acceso de NIST, OWASP, MITRE, ENISA, la Comisión Europea, el Gobierno de España y el Foro Económico Mundial. Todos ellos son citados con su referencia correspondiente en el Informe Principal.

Descargos de Responsabilidad

Este kit es un instrumento de apoyo a la autoevaluación y la planificación. No constituye asesoramiento jurídico. Para la interpretación de obligaciones legales derivadas del EU AI Act, NIS2, ENS o cualquier otro marco normativo, se recomienda consultar con asesoría jurídica especializada.

Los datos numéricos citados en el kit (porcentajes de madurez, estadísticas de incidentes, cifras de inversión) provienen de fuentes públicas verificadas (Cisco CRI 2025, INCIBE, ENISA, WEF). No han sido inventados ni simulados.

El Kit FAICP no está respaldado oficialmente por NIST, OWASP, MITRE, ENISA, AESIA ni ningún otro organismo. Es una herramienta de investigación independiente que integra y aplica marcos públicos al contexto español.

Versionado y Actualizaciones

Dado el ritmo de evolución del panorama de amenazas IA y el marco regulatorio, se recomienda verificar si existe una versión más reciente del kit antes de cada ciclo de evaluación. Los eventos que activan una actualización de versión son:

- Versión final del NIST IR 8596 (esperada 2026)
- Actualización del OWASP LLM Top 10 (v2026, prevista)
- Nuevas versiones de MITRE ATLAS
- Nuevas guías de AESIA o CCN sobre sistemas de IA
- Transposición completa de NIS2 en España

Índice Completo del Kit

KIT-FAICP-2025-2026/

— README.md	← Este fichero – Guía de uso
— 00_INFORME-FAICP-2025-2026.md	← Informe principal (estado del arte)
— a_marco-gqm-pragmatic.md	← (a) Marco GQM + PRAGMATIC
— b_matriz-pragmatic-faicp.md	← (b) Matriz de evaluación PRAGMATIC
— c_narrativa-faicp.md	← (c) Narrativa explicativa
— d_mapeo-normativo-faicp.md	← (d) Mapeo normativo detallado
— e_plantilla-igm-roi-faicp.md	← (e) Plantilla Excel IGM + ROI
— f_plantilla-ppt-faicp.md	← (f) Plantilla PowerPoint ejecutivo

Total del kit: ~120.000 palabras de contenido técnico especializado, organizado en 7 documentos complementarios.

"La ciberseguridad de la inteligencia artificial no es un problema de tecnología. Es un problema de gobernanza que la tecnología hace urgente. Este kit es una invitación a tomárselo en serio antes de que alguien más lo haga por nosotros."

Kit FAICP 2025-2026 — Versión 1.0 — Abril 2026

Distribución libre con atribución — CC BY 4.0